

Despliegue y Seguridad en Aplicaciones Web

Programa del curso

Carlos Rodríguez Contreras · carlos.mailhub@gmail.com · GitHub: karrocon

 *7 módulos · 21 topics · 1 app hackeada y reparada*

Sobre mí

Carlos Rodríguez Contreras

	Senior Software Engineer @Shopify (4+ años)
	+15 años de experiencia
	PhD en Informática — Especialidad: Automática
	TypeScript · Node.js · Go · Ruby · Cloud
	carlos.mailhub@gmail.com
	karrocon

Contenido de esta presentación

1. Presentación del curso
2. Lo que construiremos (y romperemos)
3. Herramientas del curso
4. Estructura — 7 módulos
5. Metodología



Presentación del curso

¿Qué es esto y para qué sirve?

¿Qué aprenderás?

Al terminar el curso sabrás:

-  Cómo funciona una aplicación web real
-  Cómo se explotan las vulnerabilidades del **OWASP Top 10**
-  Cómo corregirlas con código real
-  Cómo almacenar contraseñas y secretos de forma segura
-  Cómo configurar HTTPS, TLS y cabeceras HTTP
-  Cómo hacer un pentest básico con herramientas gratuitas
-  Cómo integrar seguridad en CI/CD (DevSecOps)

Datos del curso

- **Módulos:** 7
- **Topics:** 21
- **Nivel:** Iniciación/Intermedio
- **Requis.:** HTML/HTTP básico, algo de programación

 Todo el contenido de ataque es **exclusivamente** para entornos de laboratorio propios.

¿Por qué aprender seguridad web?

Estadísticas reales:

Año	Coste medio brecha	Tiempo detección
2023	4,45M USD	204 días
2024	4,88M USD	197 días

OWASP Top 10 — causas de la mayoría de brechas:

- Inyección SQL / NoSQL / Command
- Autenticación rota
- Exposición de datos sensibles
- Control de acceso defectuoso

💀 El 94% de las aplicaciones web tienen al menos una vulnerabilidad de control de acceso.
(OWASP, 2025)

✅ **Perfil DevSecOps** es uno de los más demandados en 2025.
Integrar seguridad desde el desarrollo vale mucho más que parchear después.

Vocabulario esencial de seguridad

Concepto	Definición
Confidencialidad	Solo quien debe ver los datos puede verlos
Integridad	Los datos no se modifican sin autorización
Disponibilidad	El servicio funciona cuando se necesita
Superficie de ataque	Todos los puntos donde un atacante puede actuar
Vector de ataque	El camino que el atacante usa para explotar
Vulnerabilidad	Debilidad en el código o configuración
Exploit	Técnica que aprovecha una vulnerabilidad
Riesgo	Probabilidad de ataque × Impacto
CVSS	Puntuación de severidad (0–10)

Lo que construiremos (y romperemos)

VulnApp — la aplicación del curso

VulnApp — la app de referencia

Una app web Node.js + TypeScript con:

-  Sistema de login con usuarios y roles
-  Panel de usuario y perfil
-  Sección de comentarios
-  API REST con endpoints variados
-  Base de datos SQLite
-  **Vulnerabilidades reales incluidas intencionalmente**

 **VulnApp no es una app de producción.**

Tiene vulnerabilidades **a propósito** para que puedas:

1. Atacarla tú mismo
2. Entender el problema
3. Aplicar el fix
4. Verificar que funciona

Tu recorrido por el curso



- 🦋 Clonas el repo y tienes VulnApp lista en minutos
- ● En cada topic atacas una vulnerabilidad real
- ● Luego aplicas el fix y lo verificas
- 📄 Al final del curso tienes tu propio informe de auditoría

🦋 Referencia del curso:

`VulnApp/`

Incluye `starter/` (vulnerable) y `solucion/` (corregido) por topic.

Herramientas del curso

Todo gratuito, todo en tu máquina

Stack tecnológico

Aplicación (VulnApp):

Capa	Herramienta
Lenguaje	TypeScript
Framework	Express
Base de datos	SQLite (better-sqlite3)
Runtime	Node.js 20+
Contenedores	Docker + Docker Compose

Herramientas de seguridad:

Herramienta	Para qué
OWASP ZAP	Scanner de vulnerabilidades
Burp Suite Community	Proxy / interceptar peticiones
nikto	Escáner de servidores web
nmap	Escaneo de puertos/servicios
securityheaders.com	Verificar cabeceras HTTP
SSL Labs	Verificar configuración TLS
npm audit / Snyk	Dependencias vulnerables

Instalación del entorno (T01)

- Node.js 20+ · nodejs.org.
- Docker Desktop · docker.com
- VS Code + extensión REST Client
- OWASP ZAP · zapproxy.org.
- Burp Suite Community · portswigger.net

 Ver guía de instalación paso a paso en [modulo-01/slides-t01.html](#)

```
git clone https://github.com/karrocon/taller-seguridad-web-fp
cd taller-seguridad-web-fp/VulnApp
npm install && npm start
```



Estructura del curso

7 módulos • 21 topics • 1 app hackeada y reparada

Visión general – 7 módulos

Módulo	Nombre	Topics	Resultado
1	Fundamentos y Entorno	T01-T03	VulnApp corriendo, arquitectura web entendida
2	Vulnerabilidades de Inyección	T04-T06	SQLi, XSS y Command Injection explotados y corregidos
3	Identidad y Control de Acceso	T07-T09	JWT, IDOR y CSRF explotados y corregidos
4	Datos Sensibles y Secretos	T10-T12	HTTPS, bcrypt, Key Vault configurados
5	Superficie del Servidor	T13-T15	Headers, dependencias y SSRF asegurados
6	Infraestructura y Deploy	T16-T18	App dockerizada y desplegada con HTTPS
7	DevSecOps y Cierre	T19-T21	CI/CD seguro, pentest completo, informe de auditoría

Módulo 1 – Fundamentos y Entorno

Topics:

- **T01** – Arquitectura Web y HTTP · cliente/servidor, peticiones, respuestas, DNS
- **T02** – Docker y Variables de Entorno · contenedores, `.env`, no hardcodear secretos
- **T03** – VulnApp Setup · clonar, entender el código, primer ataque básico

Resultado:

VulnApp corriendo localmente, arquitectura web comprendida

► Objetivo de módulo

Tendrás VulnApp corriendo y entenderás cómo fluye una petición HTTP de principio a fin antes de terminar T01.

📄 Materiales: `modulo-01/slides-t01...t03.html`

Módulo 2 – Vulnerabilidades de Inyección

Topics:

- **T04** – SQL Injection · payloads clásicos, blind SQLi, prepared statements
- **T05** – XSS Stored/Reflected · robo de cookies, CSP como defensa
- **T06** – Command Injection y Path Traversal · `child_process`, validación de input

Resultado:

Has explotado las 3 vulnerabilidades de inyección más comunes y aplicado los fixes

🦴 OWASP A05:2025 – Injection

Afecta a cualquier app que construya queries o comandos concatenando input de usuario. Sigue en el top 5 a pesar de 25 años de parches.

Módulo 3 – Identidad y Control de Acceso

Topics:

- **T07** – Autenticación Rota y JWT · JWT mal firmado, fuerza bruta, `alg: none`
- **T08** – IDOR y Control de Acceso · acceso horizontal/vertical, manipulación de parámetros
- **T09** – Cookies, CSRF y Session Hijacking · flags `HttpOnly`, `Secure`, `SameSite`; tokens CSRF

Resultado:

Entiendes cómo se roban identidades y cómo prevenirlo

⚠️ OWASP A01:2025 – Broken Access Control

Sigue siendo la vulnerabilidad **más frecuente** — presente en el 94% de aplicaciones analizadas.

Módulo 4 – Datos Sensibles y Secretos

Topics:

- **T10** – HTTP vs HTTPS, TLS y Cifrado · diferencias, TLS handshake, cipher suites, HSTS
- **T11** – Almacenamiento Seguro de Contraseñas · plain text → MD5 → bcrypt → Argon2; salting; timing attacks
- **T12** – Secretos en Repos y Key Vault · `.env`, git history leaks, HashiCorp Vault, Azure Key Vault

Resultado:

App con HTTPS, contraseñas hasheadas con Argon2, secretos fuera del código

¿Sabías que...?

Miles de repos públicos en GitHub contienen claves de API, contraseñas y certificados privados.

Herramienta: **truffleHog**, **git-secrets**

Módulo 5 – Superficie del Servidor

Topics:

- **T13** – Headers HTTP y securityheaders.com · CSP, HSTS, X-Frame-Options, Referrer-Policy, Permissions-Policy
- **T14** – Dependencias Vulnerables · `npm audit`, Snyk, SBOM, CVE lookup
- **T15** – SSRF y APIs Expuestas · Server-Side Request Forgery, endpoints internos expuestos, allowlist

Resultado:

App con nota A en securityheaders.com, dependencias sin CVEs conocidos, SSRF mitigado

Herramientas gratuitas:

- securityheaders.com – análisis de cabeceras
- [SSL Labs](https://ssllabs.com) – análisis de TLS
- [Snyk](https://snyk.com) – CVEs en dependencias

Módulo 6 – Infraestructura y Deploy

Topics:

- **T16** – Base de Datos Segura · mínimo privilegio, roles, backups cifrados, no exponer puerto al exterior
- **T17** – Dockerización Segura · usuario no-root, imagen mínima, secretos en tiempo de ejecución, multi-stage
- **T18** – Reverse Proxy, TLS y WAF · nginx, Let's Encrypt, rate limiting, WAF básico con headers

Resultado:

App desplegada con HTTPS real, Docker endurecido, BD inaccesible desde el exterior

Certificados gratuitos:

[Let's Encrypt](#) – TLS gratuito y automatizado con certbot

Módulo 7 – DevSecOps y Cierre

Topics:

- **T19** – CI/CD Seguro · GitHub Actions + secrets scanning, Dependabot, SAST con CodeQL
- **T20** – Pentesting Paso a Paso · qué es, OWASP ZAP spider+scan, Burp Community, informe de auditoría, responsible disclosure
- **T21** – OWASP Top 10 Repaso · mapa completo, qué has explotado, qué falta explorar

Resultado:

Pipeline con security gates, pentest documentado con informe real, visión completa del OWASP Top 10

Entrega final

Tu informe de auditoría de VulnApp:

- Vulnerabilidades encontradas
- Severidad (CVSS)
- Fix aplicado
- Evidencia (capturas)

Metodología

Cómo está organizado el material

Metodología del curso

Estructura de cada topic:

1. **Lee las slides** — teoría, mecánica del ataque, defensa
2. **Lanza VulnApp** — `cd VulnApp && npm start`
3. **Ataca** — sigue los pasos del lab con el `starter/`
4. **Corrige** — aplica el fix, consulta `solucion/` si te atascas
5. **Continúa a tu ritmo** — no hay límite de tiempo

Regla de oro:

“ Intenta el ataque y el fix antes de mirar la solución. El error es parte del aprendizaje. ”

💡 Filosofía

Cada topic termina con VulnApp más segura que al empezar.

La seguridad se aprende atacando, no solo leyendo.

Materiales del curso

Archivo	Para quién	Contenido
<code>modulo-XX/slides-tYY.html</code>	Pantalla	Slides del topic
<code>tXX/starter/</code>	Tú	Código vulnerable para el lab
<code>tXX/solucion/</code>	Referencia	Fix aplicado
<code>VulnApp/</code>	Referencia	App completa del curso

Todos los materiales disponibles en el repositorio del curso.

Criterios de evaluación

Criterio	Peso
Informe de auditoría final (T20)	50%
Labs completados por módulo	30%
Calidad del código de los fixes	20%

Entrega mínima para superar el curso:

-  Al menos 1 vulnerabilidad explotada y corregida por módulo
-  Informe de auditoría con al menos 5 hallazgos documentados
-  VulnApp desplegada con HTTPS

Importante

No se evalúa encontrar todas las vulnerabilidades, sino demostrar que entiendes el ataque, el impacto y el fix.

Resumen: lo que vas a conseguir

En este curso pasarás de:

- ✗ No saber qué es SQLi ni XSS
- ✗ Almacenar contraseñas en plain text
- ✗ Desplegar con HTTP y secretos en el código
- ✗ No saber qué herramientas usan los auditores

A:

- ✓ Explotar y corregir el OWASP Top 10
- ✓ Configurar HTTPS, bcrypt y Key Vault
- ✓ Hacer un pentest básico con ZAP y Burp
- ✓ Escribir un informe de auditoría real

→ Siguiente paso

Después de este curso puedes explorar:

- Certificación **CompTIA Security+**
- **OWASP WebGoat** para práctica adicional
- **HackTheBox / TryHackMe** para CTFs
- **PortSwigger Web Security Academy** (gratis)



→ **T01** — Entiende la arquitectura web y lanza VulnApp

→ Tienes el código vulnerable, el fix y la solución si la necesitas

✅ ¡Empieza cuando quieras!